OSCORP

3-Year Cybersecurity Roadmap

Risk based plan to strengthen governance, prevention, detection, response and resilience of OSCORP.

Prepared for: Chief Executive Officer and Executive Leadership Team

Prepared by: Senior Cyber Security Consultant (Ololade Oluwole)

Version 2.0 | October 2026

CONFIDENTIAL - FOR INTERNAL USE ONLY

Based on supplied OSCORP problem description and completed NIST CSF gap assessment workbook. This roadmap is a management plan, not an audit or certification opinion.

1. Executive Summary

OSCORP has solid foundations in network security, physical security, backups and disaster recovery. The main exposure is that these controls are not supported by a mature cybersecurity management program. The current assessment found material gaps in identity and privileged access, vulnerability management, governance, third-party risk, data protection, monitoring and incident response.

Baseline	Current Position	Management View
NIST CSF assessment	18 Pass / 73 Fail / 7 N/A	19.8% of applicable controls pass
Highest-risk gaps	MFA/PAM, shared admin credentials, high/severe vulnerabilities, no SIEM/IR capability	Immediate remediation required
Existing strengths	Firewalls/VLANs, network diagrams, BC/DR, tested backups, physical monitoring	Maintain and integrate into the wider program

Executive Priorities

- Protect identities: remove shared privileged credentials, enforce MFA, and introduce controlled privileged access.
- Reduce known exposure: establish a formal vulnerability management process with scan cadence, remediation SLAs and accountable owners.
- Create detection and response capability: centralize critical logs, implement SIEM/MDR coverage, approve an incident response plan and exercise it.
- Establish governance: approve a security strategy, policy framework, cyber risk process, risk appetite and executive reporting.
- Manage external and data risk: introduce third-party security due diligence, data classification and proportionate DLP controls.

Security practice: Year 1 should prioritize exploitable risk and control ownership before adding overlapping tools. Existing Microsoft and Palo Alto capabilities should be used where they meet requirements.

Current-State Risk Concentration

Area	Risk	Justification
Identity & privileged access	Critical	No MFA or PAM, administrator password is shared.
Vulnerability management	Critical	Qualys is used ad hoc and many high/severe vulnerabilities remain.
Detection & incident response	Critical	No SIEM or formal detection/response capability.
Governance & cyber risk	High	No cyber strategy, formal security policy or cyber risk process.
Third-party risk	High	No cyber due diligence despite critical SaaS dependency.
Data security	High	No data classification, governance policy or DLP.

2. Year 1 - Stabilize and Establish (Months 0-12)

Objective: remove the most exploitable weaknesses and put clear ownership, minimum security standards and repeatable operational processes in place.

First 90 Days

- Disable shared administrator credentials, issue named privileged accounts and start logging privileged activity.
- Enforce MFA for administrators and remote access first, then schedule workforce-wide rollout.
- Triage high and severe Qualys findings, assign owners and remediation dates, define emergency patching for critical exposure.
- Approve a cybersecurity charter, accountable control owners, initial risk register and incident escalation path.
- Identify critical log sources and select the minimum viable SIEM/MDR approach.

Year 1 Work Plan

Area	Priority actions	Owner	Annual Success Metrics
Governance & risk	Approve cyber strategy, information security policy, risk methodology, risk register and exception process. Report material risks quarterly.	CEO / Cybersecurity / Risk	Named owners, approved policies, quarterly risk report
Identity & access	Complete MFA rollout, remove shared accounts, document joiner/mover/leaver process, perform first access review.	IT / Cybersecurity	100% MFA, no shared privileged credentials, access review completed
Vulnerability management	Set authenticated scan cadence, severity-based SLAs, remediation workflow, exceptions and monthly reporting.	Cybersecurity / IT	Critical/high backlog reduced, SLA compliance measured
Monitoring & response	Onboard critical identity, cloud, endpoint and firewall logs, implement SIEM/MDR, approve IR plan and run at least one tabletop.	Cybersecurity / Network / IT	Minimum viable monitoring live, IR plan tested
Third-party risk	Create supplier inventory and risk tiers, assess critical vendors, add minimum security and breach-notification clauses.	Procurement / Cybersecurity / Risk	Critical suppliers identified and assessed
Data protection	Approve classification/handling standard, identify data owners, pilot Microsoft 365 DLP for critical data.	Cybersecurity / Business	Classification standard approved, DLP pilot completed
Awareness	Move from induction-only training to annual mandatory training, phishing simulation and privileged-user training.	Cybersecurity / HR	Annual program launched, baseline metrics established

Year 1 target: materially reduce critical exposure and move the program from ad hoc activity to defined, owned controls. A ~50% pass rate is a directional planning target, not a compliance promise.

3. Year 2 - Operationalize and Integrate (Months 13-24)

Objective: make Year 1 controls repeatable, measurable and part of normal IT, procurement, risk and business processes.

Workstream	Priority actions	Owner	Annual Success Metrics
Privileged access	Implement PAM or equivalent privileged account control, require approvals, session accountability and periodic privileged access review.	IT / Cybersecurity	Privileged activity attributable and reviewed
Security operations	Expand SIEM coverage and detection use cases, establish 24/7 MDR/SOC coverage, formalize triage, escalation and case management.	Cybersecurity / MDR	Defined alert SLAs and critical sources monitored 24/7
Vulnerability & configuration	Integrate remediation with patch/change management, define secure baselines, test externally through annual penetration testing.	Cybersecurity / IT	≥90% critical/high SLA compliance, exceptions tracked
Data protection	Roll out classification labels, DLP, retention/disposal and data-owner attestations across critical repositories.	Cybersecurity / Data Owners	Critical data covered by classification and DLP
Third-party lifecycle	Make security review mandatory before onboarding/renewal, reassess critical suppliers and track remediation.	Procurement / Cybersecurity / Risk	TPRM embedded in procurement lifecycle
Cyber resilience	Add ransomware and identity-compromise scenarios to BC/DR, test technical recovery, crisis communications and executive escalation.	IT / Cybersecurity / Communications	Cyber recovery exercise completed and lessons tracked
Control assurance	Create annual control-testing schedule and evidence repository, track findings to closure.	Cybersecurity / Risk	Repeatable control testing and remediation evidence

Year 2 target: controls should operate consistently and produce reliable evidence. The directional NIST CSF pass target is ~75%.

4. Year 3 - Optimize and Assure (Months 25-36)

Objective: verify that controls work as intended, automate high-value monitoring and independently validate residual risk.

Workstream	Priority actions	Owner	Annual Success Metrics
Continuous control monitoring	Automate reporting for identity, logging, vulnerability, supplier and data controls, trigger remediation when thresholds are missed.	Cybersecurity / IT / Risk	Executive dashboards based on reliable control data
Threat-led testing	Use threat intelligence, purple-team exercises and targeted adversary simulation to test preventive and detective controls.	Cybersecurity / MDR	Detection gaps identified, fixed and retested
Identity maturity	Optimize conditional access, service accounts and least privilege, adopt stronger/passwordless authentication where practical.	IT / Cybersecurity	Reduced credential attack surface and access exceptions
Data & supplier assurance	Extend DLP and supplier monitoring, test critical supplier contingency/exit plans, require evidence of remediation.	Cybersecurity / Procurement / Data Owners	Critical external and data risks continuously monitored
Independent assurance	Perform independent NIST CSF reassessment and targeted penetration/audit testing. Consider ISO 27001 only if business or customer requirements justify it.	Executive / Cybersecurity / Assurance	≥90% applicable controls passing or formally risk-treated

Year 3 target: demonstrate control effectiveness, not just implementation. Residual material risks should have explicit treatment or executive acceptance.

5. Governance, Reporting and Measures

Cybersecurity is an enterprise risk. The cybersecurity team coordinates the program, but control owners remain accountable for implementation and executives remain accountable for material risk decisions. The CEO may choose to delegate day to day task as per discretion but he is accountable for overall success/failure of the roadmap.

Accountability

Role	Accountability
CEO / Executive Leadership	Approve strategy and risk appetite, fund priorities, accept material residual risk.
Cybersecurity Steering Committee	Review roadmap, major risks, exceptions and cross-functional blockers quarterly.
Senior Cyber Security Consultant	Own roadmap, policy framework, risk assessment, control design and executive reporting.
IT / Network	Operate identity, endpoint, cloud, firewall, backup, patching and logging controls.
Risk / Procurement / Business Owners	Integrate cyber risk, supplier due diligence, data ownership and business risk acceptance.

Reporting

- **Monthly operations:** critical vulnerabilities, security incidents, logging coverage, access exceptions and overdue remediation.
- **Quarterly executive review:** top cyber risks, roadmap progress, supplier risk, risk acceptance and KPI/KRI trends.
- **Annual assurance:** NIST CSF reassessment, policy review, penetration test results and incident/recovery exercise outcomes.

Core Measures

Metric	Baseline	End Y1	End Y2	End Y3
MFA coverage	0% evidenced	100%	100%	100% + stronger authentication where practical
Shared privileged credentials	Present	0	0	0
Critical log coverage in SIEM/MDR	0%	≥80%	≥95%	≥95% + tested detections
Critical/high vulnerability SLA compliance	Not measured	Baseline set	≥90%	≥95%
Critical suppliers assessed	0%	Highest-risk assessed	100%	100% + ongoing monitoring
IR exercises	0 evidenced	1 tabletop	2/year	2+/year including technical exercise
Critical data under classification/DLP	0% evidenced	Pilot	≥75%	≥90%

6. Executive Decisions Required

- Approve the three-year roadmap and authorize Year 1 as the immediate risk-reduction phase.
- Name an executive sponsor and require quarterly cybersecurity risk reporting.
- Mandate MFA and removal of shared privileged credentials, exceptions require documented risk acceptance.
- Authorize SIEM/MDR, PAM and DLP capability where existing licensing does not adequately meet the control requirement.
- Require procurement and business owners to complete cybersecurity due diligence for critical suppliers.
- Approve a cyber risk appetite and require material residual risk to be accepted by the appropriate executive owner.

Recommended CEO decision: approve Year 1 mobilization now, with the first 90 days focused on privileged access and MFA, critical vulnerability reduction, governance and incident response foundations.